

Informe de TP_TryHackMe

6. PARTE II: PLANTILLA DE INFORME

6.1. Datos generales

- **Ciente:** INSECUR, S.A.
- **Contratista:** Fabricio Funes
- **Username TryHackMe:** fabroo2005
- **Sala de elección (Nivel 2)**
- **Branch en GitHub:** Funes-Fabricio
- **Fecha de cierre:** 08/10/2026

6.2. Pre-pentesting

- **Alcance del trabajo:** Únicamente los entornos de laboratorio de la plataforma TryHackMe asignados (Basic Pentesting). Quedan excluidos sistemas de producción reales.
- **Reglas de Enfrentamiento (ROE):** Pruebas de penetración sin límite de tráfico sobre la IP de la máquina virtual proporcionada por la VPN de la plataforma.
- **Autorización:** Cuento con autorización de la cátedra para trabajar sobre los entornos de TryHackMe indicados.
- **Metodología utilizada:** Metodología basada en PTES (Penetration Testing Execution Standard) abarcando fases de escaneo, enumeración, explotación y post-explotación.

6.3. Durante: Hallazgos por fase

H-01

- **Fase:** Reconocimiento / Escaneo.
- **Descripción:** Descubrimiento de directorio oculto público (/development) con información sensible en el servidor web apache.
- **Componente afectado:** Servidor Web (Puerto 80).
- **CVSS estimado:** Medio.
- **Evidencia / Herramienta:** gobuster dir -u http://<IP> -w common.txt / Herramienta: Gobuster.
- **Impacto CIA:** Confidencialidad.
- **Salvaguarda:** Restringir el acceso a directorios de desarrollo y deshabilitar el listado de directorios.

H-02

- **Fase:** Explotación.

- **Descripción:** Acceso exitoso al sistema mediante ataque de fuerza bruta sobre el servicio SSH debido al uso de credenciales débiles (jan:armando).
- **Componente afectado:** Servicio SSH (Puerto 22).
- **CVSS estimado:** Alto.
- **Evidencia / Herramienta:** hydra -l jan -P rockyou.txt ssh://<IP> / Herramienta: Hydra.
- **Impacto CIA:** Confidencialidad, Integridad, Disponibilidad.
- **Salvaguarda:** Implementar políticas de contraseñas robustas y configurar fail2ban para bloquear ataques de fuerza bruta.

H-03

- **Fase:** Post-explotación.
- **Descripción:** Llave privada SSH (id_rsa) del usuario kay expuesta en el sistema, protegida con una contraseña débil (beeswax) vulnerable a cracking de diccionarios.
- **Componente afectado:** Sistema de archivos local (directorio .ssh).
- **CVSS estimado:** Crítico.
- **Evidencia / Herramienta:** ssh2john id_rsa > hash.txt y john --wordlist=rockyou.txt hash.txt / Herramientas: John the Ripper, ssh2john.
- **Impacto CIA:** Confidencialidad, Integridad, Disponibilidad.
- **Salvaguarda:** Utilizar passphrases largas (más de 16 caracteres) para cifrar las llaves SSH y restringir los permisos de lectura de otros usuarios.

H-04

- **Fase:** Post-explotación.
- **Descripción:** Escalada de privilegios exitosa al usuario kay mediante su llave privada, obteniendo acceso a un archivo de respaldo (pass.bak) que contenía la contraseña final.
- **Componente afectado:** Cuenta de usuario kay y archivos confidenciales.
- **CVSS estimado:** Crítico.
- **Evidencia / Herramienta:** ssh -i id_rsa kay@<IP> y cat pass.bak / Herramienta: SSH.
- **Impacto CIA:** Confidencialidad.
- **Salvaguarda:** Evitar almacenar contraseñas en texto plano dentro de archivos de respaldo (.bak).

6.4. Resumen ejecutivo de hallazgos

- **Crítico:** 2 (H-03, H-04)
- **Alto:** 1 (H-02)
- **Medio:** 1 (H-01)

- **Bajo:** 0

6.5. Post-pentesting: Recomendaciones

- **Técnicas:** Deshabilitar la autenticación por contraseña en SSH (permitir solo llaves públicas). Eliminar directorios de desarrollo (/development) del entorno de producción. Restringir permisos de lectura en la carpeta /home entre usuarios.
- **Administrativas:** Obligar al personal a utilizar bóvedas de contraseñas (Password Managers) en lugar de guardar claves en archivos de texto plano. Capacitar sobre la creación de contraseñas seguras.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

- **Escenario de falla:** Caída o bloqueo masivo del servicio SSH debido al ataque agresivo de fuerza bruta (Hydra), causando una denegación de servicio (DoS) involuntaria.
- **Impacto sobre la continuidad:** Imposibilidad de los administradores legítimos de INSECUR S.A. para acceder remotamente a los servidores para tareas de mantenimiento, afectando la operatividad por el tiempo que dure el bloqueo.
- **Plan de respuesta:**
 1. **Activación:** Detección de múltiples intentos fallidos de conexión o pérdida de conectividad SSH alertada por el sistema de monitoreo (ej. Zabbix/Nagios).
 2. **Contención:** Bloqueo temporal de la IP atacante a nivel firewall / router perimetral.
 3. **Recuperación:** Reinicio del demonio SSH o acceso a través de la consola de hipervisor (fuera de banda) para desbloquear las cuentas legítimas afectadas.
 4. **Comunicación:** Notificación inmediata al equipo de infraestructura y operaciones.
 5. **Post-mortem:** Análisis de logs (/var/log/auth.log) para implementar Fail2Ban y evitar futuros agotamientos de recursos.
- **RTO y RPO estimados:**
 - **RTO:** 1 hora.
 - **RPO:** 0 horas (no hay pérdida de datos, solo pérdida temporal de acceso).

Anexo D - Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma: *Fabrizio Funes*